Informe de Seguridad

NovaVisión ERP — Sistema de gestión clínica
Generado el 21/10/2026

Este documento resume las medidas de seguridad implementadas y verificadas en el código del sistema para prevenir vulnerabilidades. El sistema cuenta con una base de seguridad de nivel producción que cubre las principales categorías del OWASP Top 10.

Autenticación y sesiones

- Contraseñas cifradas con **bcrypt** (salt único por usuario, nunca en texto plano).
- Tokens **JWT firmados (HS256)** con secreto tomado del entorno, no embebido en el código; expiración de 8 horas.
- Revocación de sesiones: blacklist de tokens persistente en MongoDB más **token_version** para cerrar todas las sesiones de un usuario a la vez.
- Tokens con algoritmo **none**, firma inválida o expirados son rechazados (con pruebas automatizadas).

Protección contra ataques de acceso

- **Rate limiting** en login: máximo 5 intentos por minuto (y 200/min global).
- **Bloqueo de cuenta** tras 5 intentos fallidos durante 15 minutos.
- Protección contra **inyección NoSQL** (operadores $gt, $regex en el login), con pruebas.
- Protección contra **mass assignment** (un usuario no puede auto-asignarse el rol administrador).

Control de acceso

- Permisos por **rol** evaluados en cada petición (require_permission / require_roles).
- Las respuestas de usuario **nunca** incluyen el campo de contraseña.
- Cuentas inactivas rechazadas automáticamente.

Cabeceras y transporte

- **X-Frame-Options: DENY** y CSP frame-ancestors 'none' (anti-clickjacking).
- X-Content-Type-Options: nosniff, X-XSS-Protection, Referrer-Policy y Permissions-Policy.
- **HSTS** forzado en producción (HTTPS obligatorio).
- **CORS restringido** a orígenes concretos (preview y dominio de producción), no comodín.

Auditoría y trazabilidad

- **Log de auditoría** persistente de acciones sensibles (quién, qué y cuándo).
- Panel de seguridad con conteo de inicios de sesión fallidos en 24 horas.
- Los errores no exponen trazas internas (stack traces) al cliente.

Integridad de datos críticos (ERP)

- Kárdex de inventario **sin endpoints de borrado ni edición** (inmutable por diseño).

- Expedientes de evaluación con **sellado** automático (no editables tras su cierre).

Resumen: el sistema tiene una base de seguridad sólida y de nivel producción para un ERP clínico, con una suite de pruebas de seguridad automatizadas (tests/test_security.py). Para mayor profundidad puede realizarse una auditoría de seguridad formal y exhaustiva de todos los endpoints.